Model Infrastruktur

Sistem Layanan Biro Umum & Rumah Tangga
Kementerian Ketenagakerjaan

Dokumen ini menjelaskan model infrastruktur aplikasi: topologi dan komponen sistem, teknologi yang digunakan, lingkungan pengembangan dan produksi, konfigurasi, database, penyimpanan berkas, jaringan, keamanan, pencatatan log, serta prosedur backup, pemulihan, dan deployment.

Dokumen	Model Infrastruktur
Sistem	Aplikasi Layanan Biro Umum & Rumah Tangga (web internal)
Kode sumber	biro-umum-app (backend/ & frontend/)
Tanggal	10 November 2026
Disusun oleh	Tim Biro Umum & Rumah Tangga

Daftar Isi

1. Topologi Sistem 3

2. Komponen & Teknologi 5

3. Lingkungan 6

4. Konfigurasi Environment (backend/.env) 6

5. Database 7

6. Penyimpanan Berkas 7

7. Jaringan & Port 7

8. Keamanan 8

9. Logging & Pemantauan 8

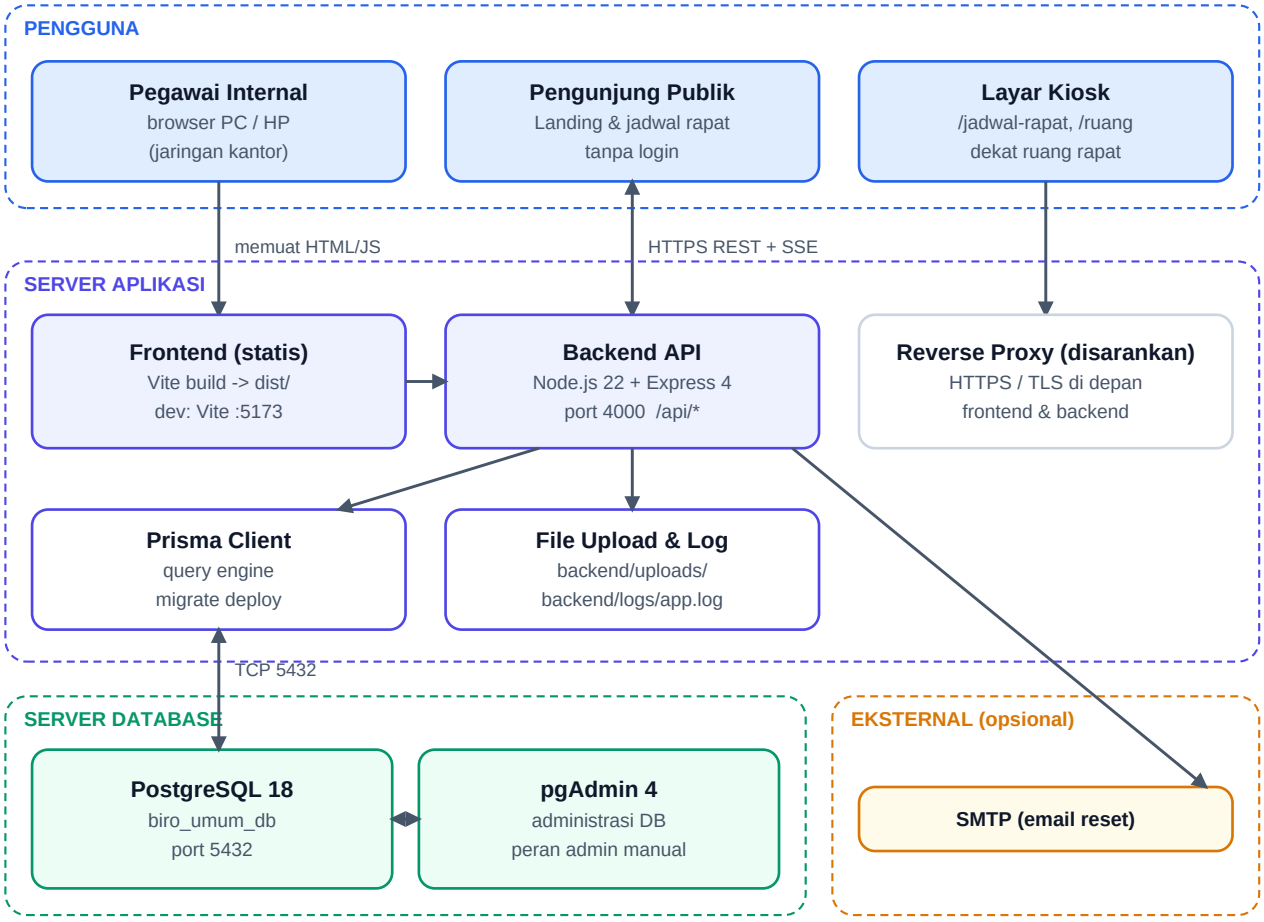
10. Backup & Pemulihan 10

11. Prosedur Deployment 10

12. Rekomendasi Pengembangan Infrastruktur 10

1. Topologi Sistem

Sistem terdiri atas frontend statis (hasil build Vite), backend REST API Node.js, database PostgreSQL, dan penyimpanan berkas di disk server aplikasi. Layanan eksternal (SMTP) bersifat opsional dan hanya aktif bila dikonfigurasi.



Gambar 1. Topologi infrastruktur

Arus komunikasi

- Browser memuat berkas statis frontend, lalu memanggil backend di `/api/*` (JSON melalui HTTP/HTTPS).
- Pembaruan real-time memakai **Server-Sent Events** (koneksi HTTP satu arah yang tetap terbuka): satu koneksi per tab ke `/api/live/stream` untuk semua modul (Pemeliharaan, Pengadaan, Kendaraan, Ruang Rapat, Maintenance, Akun). Setiap perubahan data yang berhasil mengirim sinyal nama modul, lalu halaman yang terbuka mengambil ulang datanya setelah jeda acak 0-2 detik per tab (supaya ribuan tab tidak refetch serentak). Heartbeat 25 detik, reconnect otomatis 3 detik, dan setelah reconnect semua halaman memuat ulang sekali.
- Syarat deploy real-time: backend dijalankan sebagai satu proses (bukan cluster/beberapa instance), reverse proxy tidak mem-buffer `/api/live/stream`, dan TRUST_PROXY=true bila di belakang proxy.
- Kapasitas: maks. 5.000 koneksi live total dan 3.000 per IP (`SSE_MAX_TOTAL`, `SSE_MAX_PER_IP`); Nginx perlu `worker_connections` besar (tiap koneksi live = 2 koneksi Nginx). Log request ditulis async ke `logs/app.log` (log error tetap sinkron; `LOG_HTTP_CONSOLE=false` di production supaya baris per request tidak ikut dicetak ke console).
- **Cache respons bersama** (`backend/src/responseCache.js`, `RESPONSE_CACHE_MS`, default 5 detik) untuk daftar yang isinya sama bagi semua pengguna: Pemeliharaan, Pengadaan, Kendaraan, jadwal Ruang Rapat (internal & publik), Dashboard, status maintenance, dan info ruang. Dipasang setelah cek

login/role/maintenance; setiap perubahan data lewat aplikasi langsung mengosongkan cache; request bersamaan untuk URL yang sama menunggu satu query; isi disimpan juga dalam bentuk gzip (daftar ribuan baris beberapa MB terkirim ratusan KB).

- Login/logout tidak lagi mengirim sinyal live ke semua tab (kolom "Terakhir Login" di menu Akun terbarui saat halaman dibuka ulang). Cek kata sandi (bcryptjs) berjalan di worker thread (`backend/src/password.js`) sehingga lonjakan login tidak memperlambat pengguna lain.
- Load test lokal 4 Nov 2026 (data uji 4.000 pemeliharaan, 4.000 pengadaan, 23.555 booking; ada penyimpanan data tiap 2 detik): 500 pengguna aktif terus-menerus -> median 15 ms, 0 gagal; 1.000 -> median 80 ms; 2.000 -> median 0,37 detik, ~1.000 request/detik; 2.000 pengunjung landing page -> median 5 ms, 0 gagal; 3.000 koneksi live tersambung semua. Sebelum optimasi, 200 pengguna saja sudah median 9 detik.
- Hemat beban server: tab yang tersembunyi tidak polling dan menunda muat ulang dari sinyal SSE; Nginx mengompres (gzip) JS/CSS/JSON/CSV kecuali stream SSE; berkas `/assets/` ber-hash di-cache 30 hari; frontend dipecah per halaman sehingga unduhan pertama sekitar setengah dari sebelumnya.
- Backend mengakses PostgreSQL melalui Prisma Client (TCP 5432); pgAdmin 4 dipakai admin untuk administrasi database.
- Berkas unggahan disimpan di `backend/uploads/` dan tidak diekspos sebagai folder publik; isi berkas hanya diambil lewat endpoint yang terautentikasi.

2. Komponen & Teknologi

Lapisan	Komponen	Versi / keterangan
Frontend	React, React DOM	18.3
	React Router DOM	6.24 (routing SPA)
	Axios	1.7 (HTTP client, interceptor token & 401)
	Vite + @vitejs/plugin-react	8.3 (dev server :5173, build ke dist/)
	Tailwind CSS 3 (dibundel saat build) + app-theme.css; font dibundel lokal: Inter variabel (isi), Plus Jakarta Sans (judul), JetBrains Mono (jam)	Styling & animasi, tanpa CDN
Backend	Node.js	22 LTS
	Express	4.19 (REST API, port 4000)
	Prisma ORM & Prisma Client	6.19
	jsonwebtoken	9 (JWT HS256, masa berlaku 8 jam)
	bcryptjs	2.4 (hash kata sandi, cost 12)
	nodemailer	10 (email reset kata sandi, opsional)
	cors, dotenv	CORS & konfigurasi environment
Database	PostgreSQL	18 (database biro_umum_db, port 5432)
	pgAdmin 4	Administrasi database & pemberian peran admin
Tooling	nodemon	Auto-restart backend saat pengembangan

Struktur kode sumber

Folder	Isi
backend/src/routes	auth, dashboard, pemeliharaan, pengadaan, kendaraan, ruangRapat, maintenance, users
backend/src/middleware	auth (JWT & peran), maintenance, security (header, rate limit, batas SSE)
backend/src	prisma.js, validate.js, fileStorage.js, fileSignature.js, token.js, mailer.js, logger.js
backend/prisma	schema.prisma dan 30 migration (sumber kebenaran skema)
backend/scripts	db-verify.js (cek kolom & jumlah baris), cleanup-uploads.js (berkas yatim)
backend/sql	production_schema.sql (instalasi database production baru), role_management.sql, arsip pra-Prisma
frontend/src	pages, components, context (AuthContext), live.js + hooks (useLive, SSE), utils

3. Lingkungan

Aspek	Pengembangan (lokal)	Produksi (disarankan)
Frontend	npm run dev (Vite, http://localhost:5173)	npm run build, berkas dist/ disajikan web server/reverse proxy
Backend	npm run dev (nodemon, http://localhost:4000)	npm start di bawah process manager (mis. PM2/NSSM) agar otomatis restart
Database	PostgreSQL 18 lokal (localhost:5432)	Server PostgreSQL terpisah/terkelola dengan backup terjadwal
Skema	npx prisma migrate deploy	npx prisma migrate deploy saat rilis
Akses	HTTP	HTTPS melalui reverse proxy, TRUST_PROXY=true
Berkas	backend/uploads di disk lokal	Disk persisten + backup, atau object storage (S3-compatible)

Catatan: platform serverless (mis. Vercel) tidak menyimpan berkas lokal secara permanen, sehingga backend sebaiknya dijalankan di server/VPS dengan disk persisten.

4. Konfigurasi Environment (backend/.env)

Variabel	Wajib	Fungsi
DATABASE_URL	Ya	Koneksi PostgreSQL (postgresql://user:pass@host:5432/biro_umum_db)
JWT_SECRET	Ya	Kunci tanda tangan token, minimal 32 karakter (server menolak start bila kurang)
JWT_EXPIRES_IN	Tidak	Masa berlaku token, default 8h
JWT_REMEMBER_EXPIRES_IN	Tidak	Masa berlaku token bila "Ingat saya" dicentang, default 30d
APP_TIMEZONE	Tidak	Zona waktu kantor untuk tanggal/jam hari ini (booking tamu, dashboard), default Asia/Jakarta
FRONTEND_URL	Ya	Origin yang diizinkan CORS & dasar link reset kata sandi
PORT	Tidak	Port backend, default 4000
TRUST_PROXY	Tidak	true bila di belakang reverse proxy agar IP klien terbaca benar
HOST	Tidak	Alamat yang didengarkan backend; default 127.0.0.1 bila TRUST_PROXY=true, selain itu 0.0.0.0
PRISMA_LOG	Tidak	true untuk log peringatan Prisma
SMTP_HOST / PORT / USER / PASS, MAIL_FROM	Tidak	Mengirim email reset kata sandi; bila kosong permintaan masuk ke notifikasi admin
GOOGLE_CLIENT_ID / CLIENT_SECRET / CALLBACK_URL	Tidak	Login Google untuk tamu booking ruang rapat; CALLBACK_URL (…/api/auth/google/callback) harus terdaftar di Google Cloud Console. Bila kosong tombol login Google menampilkan pesan belum dikonfigurasi
VITE_API_URL (frontend)	Tidak	Alamat API untuk frontend, default http://localhost:4000/api

5. Database

- DBMS PostgreSQL 18, database `biro_umum_db`, skema `public`; 8 tabel inti + tabel riwayat migration Prisma (`_prisma_migrations`).
- Perubahan struktur **hanya** melalui migration Prisma (0001 s.d. 0030) agar Prisma dan pgAdmin 4 selalu sinkron. Database production baru bisa dibuat sekali jalan dengan `backend/sql/production_schema.sql` (setara 0001 s.d. 0030, sudah mengisi `_prisma_migrations`). Cek sinkron: `npx prisma migrate status` dan `npx prisma migrate diff --from-schema-datasource ... --to-schema-datamodel ...` (read-only).
- Integritas dijaga di level database: UNIQUE (email, kode, plate, menu_key, service per tanggal), CHECK (kategori, status surat, jam & tanggal booking), foreign key dengan SET NULL/CASCADE, trigger updated_at & tanggal_selesai.
- Konkurensi booking ruang rapat memakai *advisory lock* per ruangan di dalam transaksi sehingga dua booking bersamaan tidak lolos cek bentrok.
- **Peringatan:** jangan pernah memakai DATABASE_URL produksi/utama sebagai `--shadow-database-url`; Prisma mengosongkan shadow database.

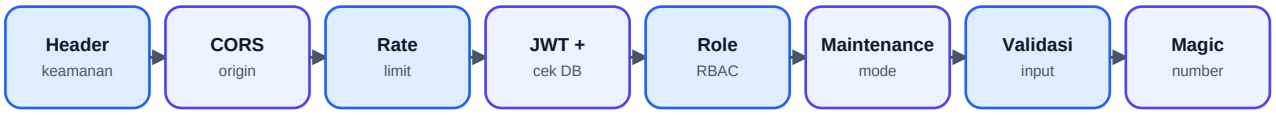
6. Penyimpanan Berkas

- Berkas dikirim dari browser sebagai data URL Base64, divalidasi (tipe, ukuran, magic number), lalu disimpan ke `backend/uploads/<modul>/<tahun>/<bulan>/` dengan nama acak (timestamp + UUID). Ekstensi ditentukan dari tipe terverifikasi, bukan dari nama berkas.
- Isi berkas juga tersimpan di kolom `*_file_data` database untuk kompatibilitas; path disk tidak pernah dikirim ke klien.
- Foto kendaraan dikompres di browser (maks. 1600 px, JPEG kualitas 0.75) sebelum diunggah.
- Berkas yang tidak lagi direferensikan dapat dirapikan dengan `npm run uploads:cleanup` (laporan) atau `--apply` (dipindah ke uploads/_orphaned, tidak dihapus).

7. Jaringan & Port

Komponen	Port / protokol	Diakses oleh
Frontend (dev)	5173 / HTTP	Browser pengguna
Backend API	4000 / HTTP(S), JSON + SSE	Browser (origin FRONTEND_URL)
PostgreSQL	5432 / TCP	Backend & pgAdmin 4 saja (jangan dibuka ke publik)
SMTP	465 (SSL) atau 587 / keluar	Backend (opsional)

8. Keamanan



Urutan pemeriksaan setiap request API sebelum menyentuh database/berkas

Gambar 2. Lapisan pemeriksaan keamanan pada setiap request

Kontrol	Implementasi
Header keamanan	API: CSP, X-Frame-Options DENY, X-Content-Type-Options nosniff, Referrer-Policy, Permissions-Policy, COOP/CORP; header X-Powered-By dimatikan. Halaman web (Nginx, docs/deploy/security-headers.conf): HSTS 1 tahun, CSP script-src 'self' (tanpa script inline), Referrer-Policy no-referrer, X-Frame-Options DENY.
Server web	Nginx: hanya TLS 1.2/1.3, HTTP dialihkan ke HTTPS, versi Nginx disembunyikan (server_tokens off), file tersembunyi (.env, .git) ditolak.
CORS	Hanya origin FRONTEND_URL; metode GET/POST/PUT/DELETE/OPTIONS.
Cache & HSTS	Semua respons /api diberi Cache-Control: no-store (foto ruang publik menimpa dengan cache panjang); HSTS dikirim backend bila request datang lewat HTTPS (TRUST_PROXY=true).
Rate limit	Global 180 request/menit per akun (per IP bila belum login); login 5/menit per IP+email, 20 per 15 menit per akun (semua IP) dan 120/menit per IP; batas tabel limiter 50.000 kunci (penuh = 429); daftar 50/jam; lupa sandi 5/jam; reset 20/jam; koneksi SSE maks. 200 per IP & 1000 total. Tamu Google: captcha 10/menit, submit booking 6/10 menit per akun & 20/10 menit per IP.
Captcha & anti-spam tamu	Captcha 6 angka berupa gambar PNG yang digambar server (jawaban tidak ada di kode sumber gambar), disimpan sebagai hash, berlaku 5 menit, satu per akun dan hangus setelah sekali dicek. Jeda 60 detik, maks. 3 pengajuan/24 jam & 5 booking aktif per akun (dikunci advisory lock per akun).
Autentikasi	JWT HS256 berlaku 8 jam; peran & status aktif dibaca ulang dari database setiap request; akun yang di-ban langsung ditolak (kode ACCOUNT_BANNED) dan dikeluarkan dari sesi. Token membawa versi sesi (users.token_version) yang naik saat logout, reset kata sandi, atau ban, sehingga token lama langsung tidak berlaku walau belum kedaluwarsa. Login dengan email tidak terdaftar tetap menjalankan bcrypt agar waktu respons sama. Token tamu Google terpisah (audience guest-booking, berlaku 7 hari, versi sesi guest_accounts.token_version) dan ditolak oleh endpoint pegawai.
Kata sandi	bcrypt cost 12; token reset acak 32 byte, disimpan sebagai hash SHA-256, berlaku 1 jam, tidak pernah ditampilkan ke peminta publik; token dikirim di #fragment link sehingga tidak tercatat di log server.
Otorisasi	RBAC per endpoint (requireRole) + aturan kepemilikan data PIC; akun Admin hanya dapat dikelola Admin (Kabag ditolak 403 saat mengubah role, mem-ban, membuat link reset, atau memverifikasi akun Admin, sehingga Kabag tidak bisa mengambil alih akun Admin); menu disembunyikan di frontend.
Validasi input	Validasi tipe, panjang, tanggal, nominal di backend (validate.js) dan frontend; body JSON maks. 25 MB hanya untuk request bertoken sah (pegawai/tamu), tanpa token maks. 256 KB (mencegah banjir body besar tanpa login); ID di URL di luar batas INTEGER ditolak 400.
SQL injection	Semua query lewat Prisma (ter-parameter); raw SQL hanya tagged template $executeRaw untuk advisory lock, tanpa $queryRawUnsafe berisi input pengguna. Query string diparse 'simple' (?a[b]=1 tidak menjadi objek) dan setiap field login/token/filter dicek bertipe teks, sehingga operator Prisma (mis. {"not": ""}) tidak bisa disisipkan ke WHERE. Middleware global (validateCommonInput) menolak karakter NUL, kunci __proto__/constructor/prototype, dan objek bersarang lebih dari 8 level.
Berkas	Whitelist MIME + pemeriksaan magic number (foto kendaraan & ruangan hanya JPG/PNG/WEBP); nama berkas disanitasi; folder uploads tidak dipublikasikan; pratinjau lewat Blob URL.
Export CSV/Excel	Sel yang diawali = + - @ diberi awalan ' (backend/src/csv.js, frontend utils/excelCell.js) supaya isi dari pengguna/tamu (mis. agenda "=HYPERLINK(...)") tidak dijalankan Excel sebagai rumus.
Jaringan backend	Bila TRUST_PROXY=true, backend hanya mendengarkan 127.0.0.1 (HOST bisa diubah), sehingga header X-Forwarded-For tidak bisa dipalsukan dari luar untuk lolos dari rate limit login.
Maintenance	Menu dapat dikunci (HTTP 503) tanpa mematikan server.

9. Logging & Pemantauan

- Setiap request dicatat ke `backend/logs/app.log` dalam format JSON per baris: waktu, request_id, metode, path, status, durasi, user_id, peran.
- Error server dicatat lengkap (pesan, kode Prisma, stack) untuk pelacakan; setiap respons membawa header `X-Request-ID` untuk mencocokkan laporan pengguna dengan log.
- Endpoint `GET /api/health` untuk pemeriksaan hidup (uptime monitor); `npm run db:test` dan `npm run db:verify` untuk cek koneksi & struktur database.
- Disarankan: rotasi app.log (mis. logrotate/harian) agar ukuran berkas tidak terus membesar.

10. Backup & Pemulihan

Data operasional berada di dua tempat: database PostgreSQL dan folder `backend/uploads/`. Keduanya harus dibackup bersamaan.

Objek	Cara backup	Frekuensi disarankan
Database	pg_dump -Fc biro_umum_db > biro_umum_YYYYMMDD.dump (atau pgAdmin 4: Backup...)	Harian + sebelum setiap migration/rilis
Folder uploads	Salin/arsipkan backend/uploads/ ke penyimpanan lain	Harian
Konfigurasi	Simpan backend/.env di tempat aman (bukan di git)	Setiap perubahan
Kode sumber	Repository git (commit & push rutin)	Setiap perubahan

Pemulihan: buat database kosong, jalankan `pg_restore -d biro_umum_db berkas.dump`, kembalikan folder uploads, lalu verifikasi dengan `npx prisma migrate status` dan `npm run db:verify`. Simpan minimal 7 salinan harian dan uji pemulihan secara berkala.

11. Prosedur Deployment

- 1) Backup database dan folder uploads.
- 2) Ambil kode terbaru, jalankan `npm install` di backend/ (otomatis `prisma generate`) dan frontend/.
- 3) Terapkan skema: `npx prisma migrate deploy`; cek dengan `npx prisma migrate status`.
- 4) Build frontend: `npm run build`, sajikan folder dist/ (fallback semua rute ke index.html) memakai docs/deploy/nginx.conf.example + security-headers.conf.
- 5) Restart backend (`npm start` via process manager); cek `GET /api/health`.
- 6) Uji singkat: login, buka tiap menu, buat & batalkan satu booking uji.
- Database lama yang dibuat dari script pgAdmin: tandai baseline dengan `npx prisma migrate resolve --applied 0001_init` sebelum migrate deploy (lihat backend/docs/PRISMA_PRODUCTION.md).

12. Rekomendasi Pengembangan Infrastruktur

- Pasang reverse proxy (Nginx/IIS) dengan sertifikat TLS dan aktifkan TRUST_PROXY=true.
- Jadwalkan backup otomatis database + uploads dan simpan salinan di lokasi terpisah.
- Pindahkan berkas ke object storage bila backend dijalankan di lebih dari satu server; pindahkan rate limit ke Redis untuk multi-server.
- Tambahkan rotasi log dan pemantauan uptime pada /api/health.
- Batasi akses port 5432 hanya dari server aplikasi dan komputer admin (firewall).